

Trusted third parties in electronic commerce

P J Skevington and T P Hart

Trusted third parties (TTPs) are often employed to facilitate trust in commercial transactions. Banks, lawyers and brokers are typical examples in everyday use. On moving to the electronic world, the environment for establishing trust is significantly changed and, consequently, TTPs are required to play new roles. Important TTP services for electronic commerce include certification, time-stamping and notarisation. This paper describes these new TTP services and the vital roles they play in electronic commerce.

1. Introduction

All commercial transactions rely on trust. In a simple purchase, a buyer must be able to trust his supplier to provide products or services that are genuine and fit-for-purpose, while the supplier must be able to trust the buyer to offer a legitimate means of payment. Confidence in the transaction may be enhanced by a variety of means. For example, the supplier may issue receipts and warranties, and the buyer may use a signature to authorise payment.

Trust is often further enhanced by the use of ‘trusted third parties’ (TTPs). Banks, credit card companies, estate agents, financial advisors and lawyers are all familiar examples in everyday use. The TTP may act as an intermediary in the transaction (e.g. a stockbroker or travel agent) or it may provide some form of ‘off-line’ service (e.g. the bank clearing system). In each case, the TTP helps to facilitate trust between the parties who wish to conduct a transaction.

The move to electronic commerce challenges many of our basic assumptions about trust. The geographical separation of buyers and sellers, often coupled with a lack of real-time visual or oral interaction, creates a number of concerns.

- How can I be sure that I am dealing with the right person?
- How can I determine whether the party I am dealing with is trustworthy?

- How can I be sure that the messages I receive during the transaction are genuine and have not been tampered with in transit?
- How can I prevent unwanted eavesdroppers from viewing my private business?
- How can I generate evidence for use in the event of a dispute (digital equivalents of signatures, receipts, warranties, etc)?

In this brave new world, there is a need for TTPs to assume new roles and responsibilities. In particular, they have important roles to play in enabling the transacting parties to:

- authenticate one another’s identities,
- check one another’s credentials,
- guarantee the integrity and confidentiality of the messages passing between them,
- settle disputes.

Certification authorities, time-stamping authorities and digital notaries are all examples of ‘new’ TTPs that have arisen to address these needs. This paper describes the services provided by these TTPs and highlights the importance of these services for the future success of electronic commerce.

2. Certification

2.1 Introduction

Digital certificates provide a mechanism whereby transacting parties can authenticate one another's identities, check one another's credentials, and guarantee the integrity and confidentiality of the messages passing between them. As such they enable spontaneous electronic transactions to occur between parties who have no prior knowledge of each other's identity or trustworthiness.

The most reliable way of identifying an individual in the digital world is via a cryptographic 'key' — a sequence of binary digits which is unique to a particular person or machine. More precisely, in a public-key cryptography scheme, each individual is represented in the digital world by a 'public key' which corresponds to a specific 'private key' that is kept secret by the individual. The public and private keys are used as a pair — typically, a message encrypted with either of the keys may be decrypted using its counterpart. The key pair may be used to provide:

- confidentiality — a public key may be used to encrypt a message such that it can only be read by a particular individual (the owner of the corresponding private key) (see Fig 1(a)),
- authentication and integrity — a public key may be used to validate that a digitally signed message was signed by a particular individual (the owner of the corresponding private key) and that the message has not been changed since it was signed (see Fig 1(b)).

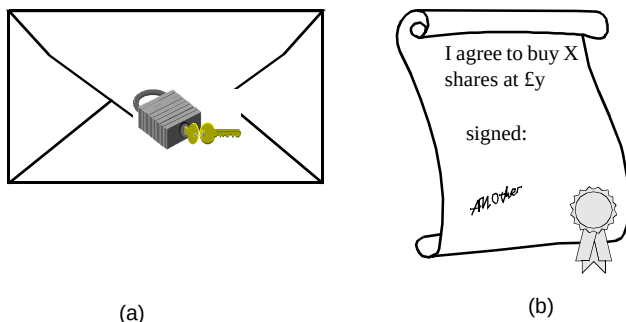


Fig 1 Schematic representations of (a) confidentiality — encrypting a message so that only the intended recipient can read it, and (b) authentication and integrity — validating that a message was signed by a particular individual and that it has not been changed since it was signed.

For a public-key scheme to operate effectively, the public keys must be made available to all users of the scheme. They may, for example, be stored in a database or published on a Web site. However, if the public keys are published as raw data objects, users cannot readily determine whether they are genuine or whether they have been tampered with. A fraudster could impersonate a user

by simply substituting his own public key in the appropriate database record. Digital certificates counter this threat.

A digital certificate provides a mechanism for guaranteeing the identity of the key's owner and/or certain credentials of the key's owner which are appropriate to the context in which the key is being used. For example, if I am about to act on some advice provided in a digitally-signed message from a financial advisor, I will require the certificate to assure me that the public key I have used to validate the signature belongs to a genuine financial expert. The digital certificate 'binds' certain information about an individual to a public key which represents that individual in the digital world. This information may include the individual's name, e-mail address, date of birth, employer's name, membership of professional bodies, credit limit, or any other appropriate attribute. The individual may not necessarily be a person — the principle applies equally well if the individual is, for example, a computer or a credit card.

For a digital certificate to be of any use, it must be issued by a third party who is trusted (directly or indirectly) by both transacting parties. A TTP who issues digital certificates is known as a certification authority (CA). The CA digitally signs the contents of each certificate. This guarantees the integrity of the certificate contents, so the certificate can be freely distributed over insecure networks. (Any attempt to tamper with the certificate contents will be immediately detectable.) In signing the certificate, the CA is also vouching for the accuracy of its contents, at least to within the constraints laid down in the CA's certification policy.

2.2 The certification process

The certification process may be decomposed into a number of steps which involve the end-user, a CA and, optionally, another party (e.g. a registration authority or key manager).

- Key pair generation — generation of a public/private key pair may be carried out by the end-user, the CA or some other party. User-generated keys are good for digital signatures and non-repudiation purposes because the user retains control of the private key at all times. However, in systems where key escrow [1] is required, either to provide data recovery or for law enforcement purposes, it may be more appropriate for some central body (e.g. the CA) to generate the key pairs. By carrying out the key generation, the CA is also in a better position to ensure that the keys are 'strong' (e.g. the quality of the random number generation may be tested) and, hence, the CA may be able to accept greater liability for their use.

- User registration — before certifying a user's public key, the CA must ensure that the user's claimed credentials are correct. Commercial CAs (e.g. Verisign [2]) typically offer various classes of certificate which differ in terms of the checks carried out. In addition, the CA must be able to prove that the public key belongs to the named individual. (This is easily achieved if the CA generates the key pair, but more difficult if the user carries out the key generation.)
- Generation of user public-key certificates — the CA must have the software required to format and sign digital certificates. The most commonly used format is based on the ISO/ITU X.509 certificate standard [3]. Each certificate has a stated validity period.
- Distribution of user public-key certificates — the certificate may be sent directly to the user, published in a directory, displayed on a WWW page or distributed by any other appropriate means. A secure distribution channel is not required, because the integrity of the certificate contents is guaranteed by the CA's digital signature.
- Publication of CA public-key certificate — the CA must have some mechanism for publishing its own public key certificate; the CA's public key is required for validating the digital signatures on user certificates. The CA certificate may be distributed to users, published in a directory, displayed on a WWW site, or embedded in the client software (e.g. Netscape Navigator 3.0 and Microsoft Internet Explorer 3.0 are both shipped with a pre-installed set of CA certificates for use with the secure sockets layer (SSL) protocol [4]).
- Certificate update process — the CA must have a process for renewing user certificates when they expire. A process for renewing the CA's own public-key certificate is also required.
- Certificate revocation process — the CA must have a mechanism for revoking certificates before they reach the end of their stated validity periods (e.g. to handle security breaches, cater for people transferring to another employer, etc). The most commonly used mechanism is the certificate revocation list (CRL). The CRL must be updated regularly and either published (e.g. using a directory or WWW site) or distributed to users. The revocation mechanism must be accompanied by a published policy outlining the conditions under which revocation will occur.

2.3 Certification architectures

As mentioned above, for digital signatures to have value, parties wishing to communicate must directly or indirectly trust the same CA. This is fine if the parties belong to the same community of interest and therefore

were registered by the same CA. However, complications arise if parties in separate communities of interest wish to communicate in a trusted manner. There are two common technical solutions to this problem, trust hierarchies and webs of trust, both of which are illustrated in Fig 2. Hybrids of these approaches also exist.

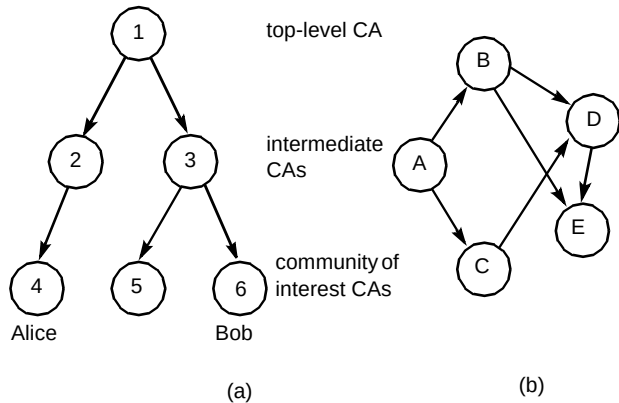


Fig 2 Trust architectures — trust hierarchy (a), and web of trust (b).

Trust hierarchy

This type of hierarchical architecture is proposed in X.509 [3]. At the top of the architecture is a top-level CA, ultimately responsible for undersigning every trust relationship in the hierarchy. Sitting in the middle layers are intermediate CAs. These CAs are granted authority by the top-level CA to undersign trust relationships required below them in the hierarchy. At the bottom of the hierarchy are CAs responsible for undersigning the trust relationships in particular communities of interest.

Imagine that in Fig 2 (a), Alice belonged to the community of interest governed by CA number 4 and held a local copy of CA number 4's and CA number 1's public-key certificates. If Alice wished for example to confirm the identity of Bob claiming to belong to the community of interest governed by CA number 6, she would validate in turn each of the public-key certificates in the chain from CA 1 down to Bob. If all the signatures were valid, Alice could encrypt data with Bob's public key trusting that the real Bob would be able to decrypt them.

In practice, it is highly debatable whether one authority would be allowed to become a global top-level CA, responsible for undersigning every single trust relationship in the world. For example, even if a national government introduced a licensing system which enabled it to undersign every certificate issued in its own jurisdiction, that government is unlikely to agree to becoming subservient to another national government (or even the United Nations)

in a global hierarchy. Instead, the top-level will probably consist of a series of players (e.g. national governments), many of whom cross-certify each other (sign each other's public-key certificates), allowing trust to flow between different communities without the need for one dominant CA.

Web of trust

A web of trust is used in Pretty Good Privacy (PGP) [5]. Unlike the regimented hierarchy of the last architecture, trust propagates throughout a web of trust in a completely unstructured manner according to each user's willingness to trust his or her colleagues. For example, in Fig 2 (b), user *A* may wish to gain trust in user *E*'s public-key certificate. User *A* may personally be happy to trust the certificate of a new user if he or she is 'introduced' by two users *A* already trusts. *A* already trusts *B* and *C*, and because both *B* and *C* trust *D*, *A* may decide to trust *D* himself. *B* and *D* trust *E*, and as *A* now trusts both *B* and *D*, *A* may decide also to trust *E*.

The advantage of a web of trust is that there is no need for any certification authorities (and definitely no need for one top-level CA). The disadvantage of a web of trust is that trust may take time to propagate across a community and users will not automatically be able to communicate with other users they have never communicated with before, perhaps making the architecture unsuitable for use in a business environment.

3. Non-repudiation services

3.1 Introduction

In many electronic commerce frameworks there will be a requirement for non-repudiation — the ability to prevent parties from denying that they previously signed an agreement.

In the paper world, important contracts and agreements may be signed in the presence of an independent witness and then a copy of the agreement may be securely archived, to be retrieved if disputes over its contents need to be resolved.

Equivalent electronic services can be provided using digital signatures. However, the legal status of digital signatures in Europe is still unclear and there is no case history defining how digital signatures should be accepted in court. Several states in America are more advanced with Utah, in particular, having recently passed laws giving digital signatures more standing than hand-written ones.

One interesting requirement for a public-key infrastructure offering non-repudiation services is that private keys should be generated locally by users, ideally on board a smart card. Obviously, the more remote the user is when the keys are generated, the further a user's private key must travel before coming into the user's possession, and the higher the likelihood that the private key is abused. For true watertight non-repudiation, it may be necessary to generate private keys only on smart cards, so that the key never leaves the card at all and therefore can only be used to sign documents by the rightful owner of the smart card.

3.2 Time-stamping

A basic on-line time-stamping service will take a document (or a compressed version of the document created by passing it through a mathematical 'hash' function [6]), append the current time to the document, digitally sign the document and time, and return the resultant time-stamp to the customer, who can then append it to the original document (see Fig 3). Assuming that a user *A* trusts the public key of the time-stamping service and *B* trusts the accuracy and integrity of the time-stamp added by the service to the original document, the user will be able to verify that data was presented to the server at a particular time and that the data has not been altered. If the lifetime of the key used by the service to sign documents is greater than

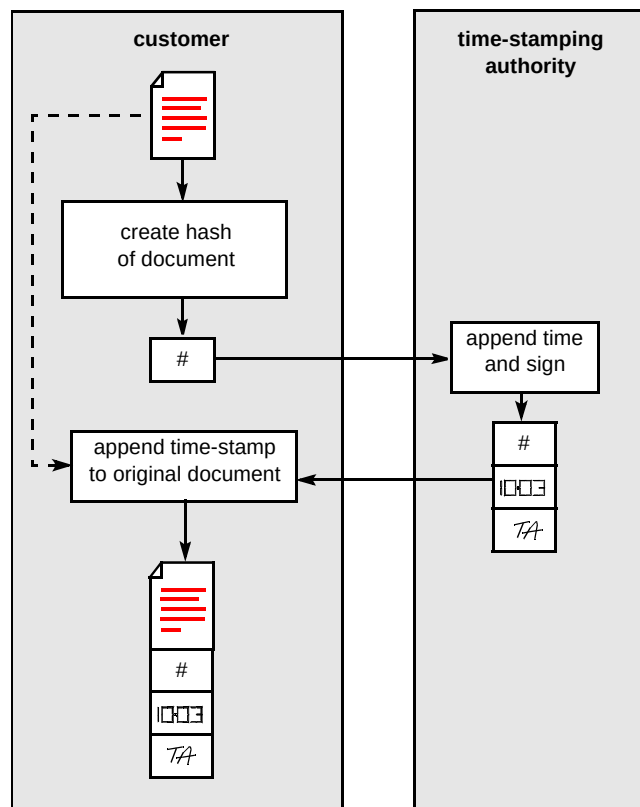


Fig 3 Schematic of a basic time-stamping service.

the lifetime of a user's key, then the time-stamp signature will also outlive any signatures in the main body of the document, effectively increasing the lifetime of the user's signature to that of the time-stamping service. Note that a time-stamping service does not examine the semantics of the information presented by a user (in fact, the user may send a hash which cannot be read by the server), and therefore does not make any statement about the status of the information when time-stamping. It also does not test to see if the information presented by the user is fresh (recently generated) and therefore a time-stamp only guarantees that a document was created sometime before the time in the time-stamp. Hence, while time-stamping services are useful for settling debates concerning intellectual property, they are less useful for settling disputes over wills, where the latest date a document was created is important. A commercial time-stamping service, based on a variant of this approach, is marketed by Surety Technologies Inc [7].

A variation on the basic on-line service is an in-line, or franking, service. Such a service will append a time-stamp to a message, before forwarding it to the intended recipient. Thus the concept of signing a document, sealing it in an envelope (encrypting it), posting it and having it franked during sorting has strong analogies in the electronic world.

3.3 Notarisation

In addition to the services described above, a notarisation service involves some type of interpretation of the presented information. The level of interpretation could involve a simple authentication of the user presenting the information, or a validation that the data is fresh, or even a negotiation stage to ensure that all parties involved in a contract are happy that the contents of a contract are correct before the information is time-stamped. This decision process that distinguishes a notarisation service from a time-stamping service will involve the contents of the message being interpreted and discussed off-line by suitable legal experts. For example, a team of solicitors may wish to provide a notarisation service for wills, electronically creating and editing wills for customers and finally time-stamping and jointly signing the resultant document with the customers when all the parties concerned are happy with the content.

3.4 Archiving

As mentioned above, a user may wish to securely archive a document after it has been time-stamped by an authority, so that it can be retrieved at a later date if a dispute needs resolving. The fact that the document has

been time-stamped and signed by the authority means that the integrity of the document can be trusted. In addition, a customer may wish to lock (encrypt) the document, but leave a copy of the encryption key with the archiving authority, or a group of customers may wish to jointly lock information so that it can only be unlocked if a certain number of the original group are present (a threshold scheme). Such encryption techniques are easily implemented using symmetric and public-key cryptography [6].

4. Trust and liability

The value of the trust placed in a TTP service is greatly increased if the TTP is prepared to accept some degree of liability when things go wrong [8]. For example, before entering into electronic contracts, customers may wish to be sure that, if the notary's private key is compromised and the contract details are changed in a manner which is unfavourable to them, they will be able to recover funds through the notary's liability insurance.

It therefore makes sense for a trusted third party to limit the scope in which the certificates it undersigns can be used. The TTP may wish to explicitly state how the certificates can be used and for what it is liable. These statements are usually included in a certificate policy document.

It is interesting to see how existing TTPs manage this liability problem. Perhaps one of the best known Internet certification authorities is Verisign [2], issuer of SSL (secure sockets layer) [4] and SET (secure electronic transactions) [9] certificates.

At the technical level, the use of, for example, SSL certificates is straightforward — they allow a merchant to enter into secure communication with a client. However, at the application level, the use of this secure communications channel is diverse and a range of different uses can already be found on the Internet.

This diverse use of the certificates, combined with the facts that the Internet is a notoriously insecure environment, revocation of compromised certificates is not straightforward, and the cryptography in browsers and servers exported from the US is weak, means that companies like Verisign may be opening themselves up to a wide range of liability claims. Verisign therefore very wisely limit themselves to a liability ranging from hundreds to thousands of dollars (depending on the class of certificate purchased). It is debatable whether true electronic commerce on the Internet can exist with this limited liability.

5. Conclusions

Trust is essential for any commercial transaction and trusted third parties, such as banks, lawyers and brokers, have traditionally played an important role in facilitating trust between transacting parties. In the world of electronic commerce, the environment for establishing trust is significantly changed. Mechanisms based on face-to-face contact and paper documentation (e.g. hand-written signatures) are largely no longer appropriate, so new mechanisms based on public-key cryptography and digital signatures are being developed. These, in turn, require the development of new TTP services such as certification, time-stamping and digital notarisation. Certification enables transacting parties to authenticate one another's identities, check one another's credentials, and guarantee the integrity and confidentiality of the messages passing between them. Time-stamping and digital notarisation provide evidence for the existence of digital documents at specific points in time and, hence, provide the basis for non-repudiation of digital transactions.

The 'new' TTPs, such as certification authorities, time-stamping authorities and digital notaries have vital roles to play in the future of electronic commerce. Perhaps one day they will be as commonplace as banks, lawyers and brokers are today.

References

- 1 Phoenix S J D: 'Cryptography, trusted third parties and escrow', BT Technol J, 15, No 2, pp 45—62 (April 1997).
- 2 Verisign, <http://www.verisign.com/>
- 3 ITU Recommendation X.509: 'The Directory — Authentication Framework', ITU, Geneva (1989).
- 4 Secure sockets layer protocol, <http://www.netscape.com/newsref/std/SSL.html>
- 5 'The Official PGP User's Guide', MIT Press, Boston, USA (1995).
- 6 Schneier B: 'Applied Cryptography', 2nd Edition, John Wiley and Sons, New York (1996).
- 7 Surety Technologies Inc, <http://www.surety.com/>
- 8 Froomkin A M: 'The Essential Role of Trusted Third Parties in Electronic Commerce', (<http://www.law.miami.edu/~froomkin/articles/trusted.htm>).
- 9 Secure electronic transactions, <http://www.visa.com/cgi-bin/vee/sf/set/intro.html?2+0>

looking



Peter Skevington joined BT Laboratories in 1985 after graduating in Physics from the University of Cambridge. He initially worked on the growth and analysis of semiconductor devices for optical transmission systems, and was awarded a PhD for this work from the University of Wales, College of Cardiff in 1993. He later joined the Applications Unit within Advanced Applications and Technologies to work on the planning of change in complex enterprises and contributed to the development of TRIADS. He is currently leading a team within Advanced Applications and Technologies into the development of trust services for electronic commerce. His interests include digital signatures, public-key infrastructures, smart cards and trusted third party services.



Timothy Hart joined BT Laboratories in 1992 after graduating in Electronic Engineering from the University of York. He initially worked in the Data Security Laboratory, evaluating third party security products and specifying the security of internal BT systems. He later joined the Advanced Applications and Technologies Future Security group, studying areas such as Internet security and electronic commerce. He is currently working on public-key infrastructures and digital signatures, as well as researching a part-time PhD looking at information protection in distributed systems.

